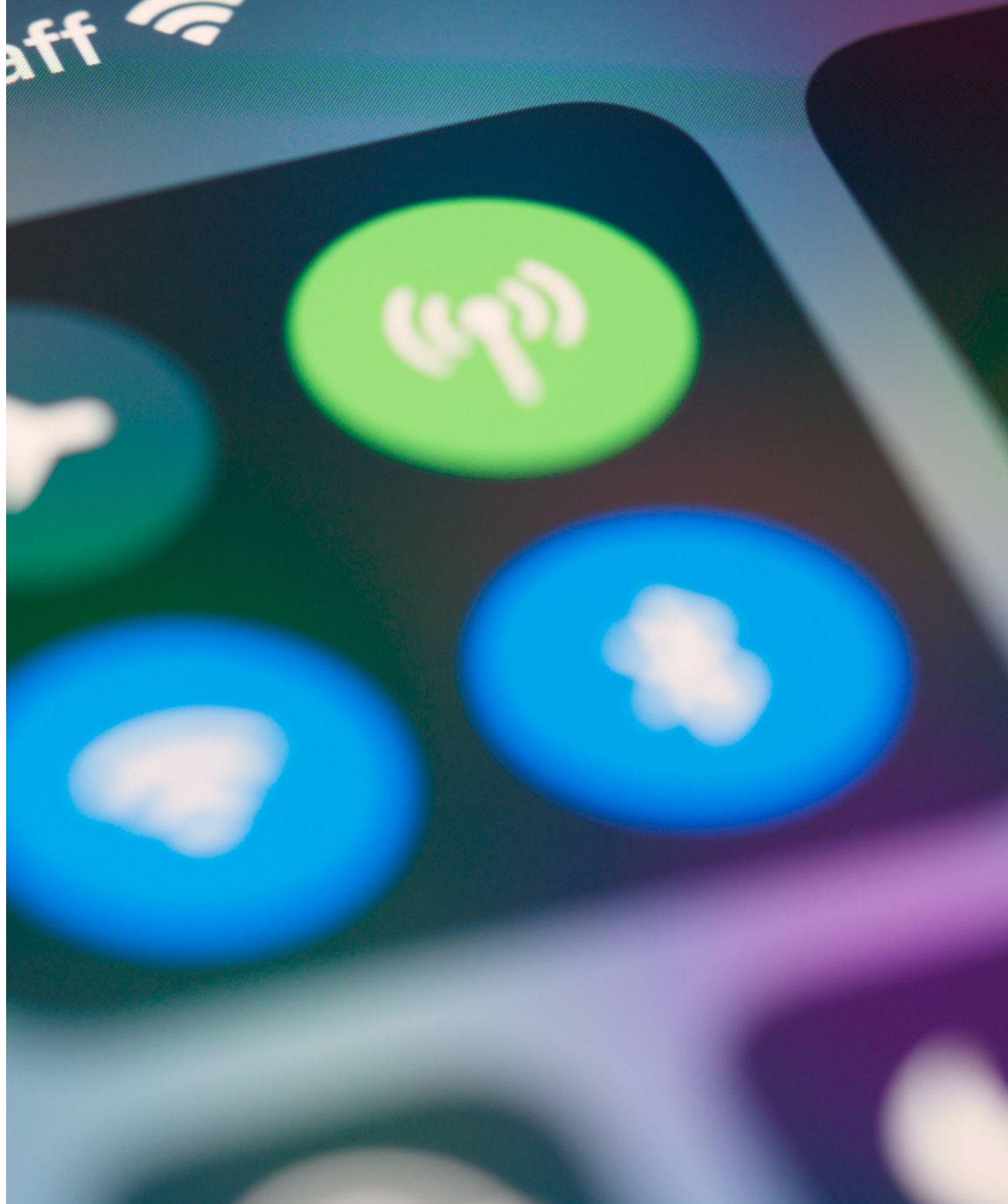


1. OVERVIEW

An overview of Requirement 4
("Protect Transmitted Data"),
and its sub-requirements.



REQ. 4: PROTECT TRANSMITTED DATA

REQ. 4: PROTECT TRANSMITTED DATA **OVERVIEW**

Requirement 4 (Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks) is about maintaining CHD secure while transmitting them across public networks, using best practices in terms of encryption.

- It also deals with the internal transmission of PANs;
- This is a very short, straightforward requirement;

This requirement focuses mostly on:

- Ensuring that you don't share plaintext data, without encryption;
- Ensuring you have up-to-date WiFi configurations and encryption protocols;
- Doing your best so attackers don't intercept your CHD;

REQ. 4: PROTECT TRANSMITTED DATA

OVERVIEW

The sub-requirements for this requirement include:

- 4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and documented.
- 4.2 PAN is protected with strong cryptography during transmission.





REQ. 4: PROTECT TRANSMITTED DATA

REQ. 4: PROTECT TRANSMITTED DATA **OVERVIEW**

4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and documented

- Our usual sub-requirement. All processes for encrypting data in transmission must be documented, updated, in use, and the same for the documentation of roles and responsibilities involved;

This is usually tested through:

- Examining the documentation of the processes and policies, as well as interviewing people to ensure these are understood and implemented;

REQ. 4: PROTECT TRANSMITTED DATA

OVERVIEW

4.2 PAN is protected with strong cryptography during transmission

- Essentially, we must only use encryption with trusted keys and certificates in public/open networks. We can't accept expired keys or certificates, or the lack of these;
- We also cannot accept versions of protocols that fall back to older or insecure versions/key sizes/etc (e.g., old SSL/TLS);
- If sending PANs via user messaging, must be encrypted;

This is usually tested through:

- Verifying CHD data transmissions to ensure PANs are encrypted, and system configurations to ensure strong cryptography is, in fact, applied;
- Examining key inventories and transmission configurations;





REQ. 4: PROTECT TRANSMITTED DATA

REQ. 4: PROTECT TRANSMITTED DATA **OVERVIEW**

How can we summarize, then, this requirement?

- The only major sub-requirement here is to always strongly encrypt transmitted cardholder data. That is it;
- We cannot use weak encryption (e.g. older 802.11, GSM, etc);
- We cannot use encryption that uses a untrusted key or certificate;
- We cannot use encryption that uses a expired key or certificate;
- We cannot use encryption protocols that fall back to previous, insecure versions/algorithms/key sizes;
- Essentially, all transmitted CHD over public/open networks needs to have strong encryption with no “but”s;

REQ. 4: PROTECT TRANSMITTED DATA

OVERVIEW

EXAMPLES

/01 NOT SENDING IS OK

In cases where the company can get by without employees sending PANs through IM/email, that is the best choice, avoiding encryption needs altogether.

/02 FIPS AS AN EXAMPLE

An example of a set of strong encryption standards is the FIPS set of standards (Federal Information Processing Standards). AES, 3DES, etc.

/03 POLICY ENFORCEMENT

This is one requirement where it's the most important to enforce a policy. One employee sending a full PAN through email immediately makes you fail PCI-DSS.

REQ. 4: PROTECT TRANSMITTED DATA

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization may ensure that their PoS systems use end-to-end encryption (E2EE) when transmitting CHD to payment processors;
- The organization configures their Wi-Fi networks with strong encryption (WPA3) and uses separate networks for payment processing and for public client usage,

E-COMMERCE STORE

- The organization ensures SSL/TLS certificates are used to encrypt data between customers and website, with the most recent version, and ensure payment pages use HTTPS;
- The organization ensures website communication with payment gateways uses TLS 1.2 or higher, and disables older TLS/SSL;

HOTEL CHAIN

- The organization uses VPNs on all devices used for transmitting CHD across hotel branches and the central reservation system;
- The organization retires usage of encrypted Excel files in email (still secure, but), replacing it with secure file transfer portals with access control by role;

PAYMENT PROCESSOR

- The organization uses robust encryption algorithms (AES-256) and protocols (TLS 1.2+) for all data transmissions including CHD (internal or with clients);
- The organization offers merchants, themselves, encrypted mechanisms, including APIs and VPNs, for CHD data submission;

REQ. 4: PROTECT TRANSMITTED DATA

OVERVIEW

KEY TAKEAWAYS

/01 PROTECT IN PUBLIC

This requirement is all about protecting cardholder data when transmitted in public. We can only transmit these data with secure encryption. Period.

/03 4.2 PROTECTING PANs

We must always transmit card data with strong encryption if the network is public/open. Encryption can't be weak, expired, older, or vulnerable.

/02 4.1 PROCESSES DEFINED

As usual, all processes and policies for this are documented, updated, in use, and the same for roles and responsibilities.